

Risk Scoring Report

Project: **vulnerable-invoice-service** · Stage 2 (Weighted CVE + Exposure + Criticality) · Generated 2026-06-22 · SHA: `61ed8c3` · Model: `0.5·CVE_severity + 0.3·exposure + 0.2·business_criticality`

Ranked Remediation Backlog

Priority	Coordinate	Risk Score	Band	Top CVE	Action
P0	com.fastxml.jackson.core:jackson-databind:2.9.8	—	Supply-chain	Typosquat	✓ Removed
P0	HTTP mirror insecure-mirror.example.net	—	Supply-chain	MITM risk	✓ Removed
P1	org.apache.logging.log4j:log4j-core:2.14.1	7.8	HIGH	CVE-2021-44228 (10.0)	✓ → 2.25.4
P1	com.fasterxml.jackson.core:jackson-databind:2.9.8	7.8	HIGH	CVE-2019-14379 (9.8)	✓ → 2.14.0
P2	mysql:mysql-connector-java:8.0.30	7.0	HIGH	CVE-2023-22102 (8.3)	⚠ MAJOR_REVIEW
P2	org.apache.logging.log4j:log4j-api:2.14.1	6.8	HIGH	CVE-2026-34479 (7.5)	✓ → 2.25.4
P2	com.google.protobuf:protobuf-java:3.19.4	6.7	HIGH	CVE-2024-7254 (7.5)	✓ Pinned 3.25.5
P3	com.google.guava:guava:24.1.1-jre	6.3	HIGH	CVE-2023-2976 (7.1)	⚠ MAJOR_REVIEW
P4	commons-io:commons-io:2.4	5.2	MEDIUM	CVE-2021-29425 (4.8)	✓ → 2.14.0
P4	org.apache.commons:commons-lang3:3.4	5.2	MEDIUM	CVE-2025-48924 (5.3)	✓ → 3.20.0

Scoring Model

Weight	Factor	Description
0.50	CVE Severity	Normalised NVD CVSS base score (0–10)
0.30	Exposure	Scope (compile/runtime) × reachability × transitive depth
0.20	Business Criticality	Service tier (external-facing vs. internal batch)

Risk Bands

Band	Threshold	Pre-remediation	Post-remediation
CRITICAL	≥ 8.0	0	0
HIGH	6.0–7.9	6	2 (MAJOR_REVIEW)
MEDIUM	3.0–5.9	3	0
LOW	< 3.0	0	0
Supply-chain	—	2	0

MAJOR_REVIEW Items (human follow-up)

com.google.guava:guava — Current: 24.1.1-jre . Minimum safe version: 32.0.0-jre . This is an 8-major-version jump with potential API breakage. Requires manual upgrade path assessment and regression testing.

mysql:mysql-connector-java — Current: 8.0.30 . CVE-2023-22102 is not fixed within the mysql:mysql-connector-java artifact (affected through 8.1.0). Fix requires migrating to com.mysql:mysql-connector-j:8.2.0+ (different groupId/artifactId). Additionally, the GPL-2.0 license requires legal review for use in a permissive-licensed project. Both the groupId change and license compliance require human decision.

Machine-readable source: `depscan-risk-report.json` . Generated by the *Dependency & Supply-Chain Plugin* — Stage 2.